GEK-SA-1046A

CCGA Communication Gateway

Secure Deployment Guide

For GE Lufkin

Nov 2015

IS420CCGAH2A and IS420CCGAH1A



GE Internal

These instructions do not purport to cover all details or variations in equipment, nor to provide for every possible contingency to be met during installation, operation, and maintenance. The information is supplied for informational purposes only, and GE makes no warranty as to the accuracy of the information included herein. Changes, modifications, and/or improvements to equipment and specifications are made periodically and these changes may or may not be reflected herein. It is understood that GE may make changes, modifications, or improvements to the equipment referenced herein or to the document itself at any time. This document is intended for trained personnel familiar with the GE products referenced herein.

GE Internal – This document contains information that belongs to the General Electric Company and is furnished to its customer solely to assist that customer in the installation, testing, operation, and/or maintenance of the equipment described. This document or the information it contains shall not be reproduced in whole or in part or disclosed to any third party without the express written consent of GE.

GE may have patents or pending patent applications covering subject matter in this document. The furnishing of this document does not provide any license whatsoever to any of these patents.

GE provides the following document and the information included therein as is and without warranty of any kind, expressed or implied, including but not limited to any implied statutory warranty of merchantability or fitness for particular purpose.

For further assistance or technical information, contact the nearest GE Sales or Service Office, or an authorized GE Sales Representative.

Revised: Nov 2015
Issued: May 2015

Copyright © 2015 General Electric Company, All rights reserved.

*** Indicates a trademark of General Electric Company and/or its subsidiaries.**
All other trademarks are the property of their respective owners.

Refer to the section, *Contact Information* for support on this product.

Please send documentation comments or suggestions to *controls.doc@ge.com*

Safety Symbol Legend



Warning

Indicates a procedure, condition, or statement that, if not strictly observed, could result in personal injury or death.



Caution

Indicates a procedure, condition, or statement that, if not strictly observed, could result in damage to or destruction of equipment.



Attention

Indicates a procedure, condition, or statement that should be strictly followed to improve these applications.

Contact Information

If you purchased this product through an Authorized Channel Partner, then contact the seller directly.

General Contact Information

Online technical support and GlobalCare	*http://support.ge-ip.com*
Additional information	*http://www.ge-ip.com/*
Solution Provider	*solutionprovider.ip@ge.com*

Technical Support

If you have technical problems that cannot be resolved with the information in this manual, please contact us by telephone or email, or on the web at *http://support.ge-ip.com*

Americas

Online Technical Support	*http://support.ge-ip.com*
Phone	1-800-433-2682
International Americas Direct Dial	1-780-420-2010 (if toll free 800 option is unavailable)
Technical Support Email	*support.ip@ge.com*
Customer Care Email	*customercare.ip@ge.com*
Primary language of support	English

Europe, the Middle East, and Africa

Online Technical Support	*http://support.ge-ip.com*
Phone	+ 800-1-433-2682
EMEA Direct Dial	+ 420-23-901-5850 (if toll free 800 option is unavailable or dialing from a mobile telephone)
Technical Support Email	*support.emea.ip@ge.com*
Customer Care Email	*customercare.emea.ip@ge.com*
Primary languages of support	English, French, German, Italian, Czech, Spanish

Asia Pacific

Online Technical Support	*http://support.ge-ip.com*
Phone	+ 86-400-820-8208
	+ 86-21-3217-4826 (India, Indonesia, and Pakistan)
Technical Support Email	*support.cn.ip@ge.com* (China)
	support.jp.ip@ge.com (Japan)
	support.in.ip@ge.com (remaining Asia customers)
Customer Care Email	*customercare.apo.ip@ge.com*
	customercare.cn.ip@ge.com (China)

Contents

1 Introduction 7

1.1 About this Guide 7
1.2 What is Security? 7
1.3 I have a firewall. Isn't that enough? 7
1.4 What is Defense in Depth? 7
1.5 General recommendations 8
1.6 Checklist 8

2 Communication Requirements 9

2.1 Protocols Supported 9
2.1.1 Ethernet Protocols 9
2.1.2 Serial Protocols 9
2.2 Ethernet Firewall Configuration 10
2.2.1 Lower-level Protocols 10
2.2.2 Application Layer Protocols 10

3 Security Capabilities 11

3.1 Firewall 11
3.2 Wi-Fi 11
3.3 Routing Information 12
3.4 Password management 13
3.4.1 SSH login 13
3.4.2 Wi-Fi login 13
3.4.3 Selecting a Strong Password 14

4 Network Architecture & Secure Deployment 15

4.1 Reference Architecture 15
4.2 Remote Access and Demilitarized Zones (DMZ) 17
4.3 Additional Guidance 17
4.3.1 Protocol-specific Guidance 17
4.3.2 Government Agencies & Standards Organizations 17

Notes

1 Introduction

1.1 About this Guide

This document provides information to improve the cyber security of systems where the Communication Gateway Module (CCGA) is used. The CCGA module is specifically used for the GE Lufkin well manager application. No other application is authorized for use with the CCGA. This document is used by control engineers, integrators, IT professionals, and developers responsible for deploying and configuring the CCGA.

Family	Catalog Number	Description
Lufkin Well Manager 2.0	IS420CCGAH1A	Communication Gateway Module without Wi-Fi
	IS420CCGAH2A	Communication Gateway Module with Wi-Fi

The following sections introduce the fundamentals of security and secure deployment.

1.2 What is Security?

Security is the process of maintaining the confidentiality, integrity, and availability of a system.

- *Confidentiality* ensures that only the people you want to see information can see it.
- *Integrity* ensures that the data is what it is supposed to be.
- *Availability* ensures that the system or data is available for use.

GE Intelligent Platforms recognizes the importance of building and deploying products with these concepts in mind and encourages customers to take appropriate care in securing their GE Intelligent Platforms products and solutions.

1.3 I have a firewall. Isn't that enough?

Firewalls and other network security products, including Data Diodes and Intrusion Prevention Devices, can be an important component of any security strategy. However, a strategy based solely on any single security mechanism will not be as resilient as one that includes multiple, independent layers of security.

Therefore, GE Intelligent Platforms recommends taking a *Defense in Depth* approach to security.

1.4 What is Defense in Depth?

Defense in Depth is the concept of using multiple, independent layers of security to raise the cost and complexity of a successful attack. To carry out a successful attack on a system, an attacker would need to find not just a single exploitable vulnerability, but would need to exploit vulnerabilities in each layer of defense that protects an asset.

For example, if a system is protected because it is on a network protected by a firewall, the attacker only needs to circumvent the firewall to gain unauthorized access. However, if there is an additional layer of defense, say a username/password authentication requirement, now the attacker needs to find a way to circumvent both the firewall and the username/password authentication.

1.5 General recommendations

Adopting the following security best practices should be considered when using GE Intelligent Platforms products and solutions.

- Deploy and configure firewalls to limit the exposure of control system networks to other networks, including internal business networks and the Internet. If a control system requires external connectivity, care must be taken to control, limit and monitor all access. Use, for example, virtual private networks (VPN) or Demilitarized Zone (DMZ) architectures.
- Harden system configurations by enabling the available security features, and by disabling unnecessary ports, services, functionality, and network file shares.
- Apply all of the latest GE Intelligent Platforms product security updates, SIMs, and other recommendations.
- Apply all of the latest operating system security patches to control system computers.
- Use anti-virus software on control system computers and keep the associated anti-virus signatures up-to-date.
- Use whitelisting software on control system computers and keep the whitelist up-to-date.

1.6 Checklist

This section provides a sample checklist to help guide the process of securely deploying GEIP controls products.

1. Create or locate a network diagram.
2. Identify and record the required communication paths between nodes.

Refer to the chapter, Communication Requirements.

3. Identify and record the protocols required along each path, including the role of each node.

Refer to the chapter, Network Architecture & Secure Deployment.

4. Revise the network as needed to ensure appropriate partitioning, adding firewalls or other network security devices as appropriate. Update the network diagram.

Refer to the section, Ethernet Firewall Configuration.

5. Configure firewalls & other network security devices.
6. Test and qualify the system.
7. Create an update/maintenance plan.

Note Secure deployment is only one part of a robust security program. This document, including the checklist above, is limited to only providing secure deployment guidance.

---

2 Communication Requirements

Communication between different parts of a control system is, and must be, supported. However, the security of a control system can be enhanced by limiting the protocols allowed, and the paths across which they are allowed, to only what is needed. This can be accomplished by disabling every communication protocol that is not needed on a particular device. Use appropriately configured and deployed network security devices (firewalls, routers) to block every protocol (whether disabled or not) that does not need to pass from one network/segment to another.

GE Intelligent Platforms recommends limiting the protocols allowed by the network infrastructure to the minimum set required for the intended application. This requires knowing which protocol is needed for each system-level interaction.

This section describes how the supported serial and Ethernet application protocols are used with the CCGA, and the role of each participant in the communication. Lower-level Ethernet protocols are not discussed, but are assumed to be supported when needed by the application protocol.

This information is intended to help guide the specification of the network architecture, and to help configure firewalls internal to that network to support only the required communications paths for any particular installation.

2.1 Protocols Supported

2.1.1 Ethernet Protocols

The following Ethernet protocols are supported by the CCGA. Some of the supported protocols may not be required in a given system, since the installation may only be using a subset of the available protocols.

Supported Ethernet Protocols

Use	Protocol
Link	ARP
Internet	IPv4
Transport	TCP
	UDP
Application	HTTPS, Modbus® TCP, SSH, EGD, SDI, DHCP, NTP

2.1.2 Serial Protocols

In addition to Ethernet, CCGA supports Modbus over serial ports (RS-232, RS-485).

2.2 Ethernet Firewall Configuration

Network-based and host-based firewalls must be configured to only allow expected and required network traffic. This section identifies the EtherTypes and the TCP/UDP ports used by the protocols supported by the CCGA.

This information should be used to help configure network firewalls to support only the required communications paths for any particular installation.

2.2.1 Lower-level Protocols

Ethernet communication is typically described using four layers, each with its own set of protocols. At the top of that hierarchy is the Application layer. Below the Application layer are the Transport, Internet, and Link layers.

Information on the supported protocols from these three lower layers is summarized in the following table.

Layer	Protocol	EtherType	IP Protocol #
Link Layer	ARP	0x0806	
Internet Layer	IPv4	0x0800	(n/a)
Transport Layer	TCP	0x0800	6
	UDP	0x0800	17

Each of these lower-level protocols are required by one or more of the Application protocols supported by the CCGA.

2.2.2 Application Layer Protocols

The CCGA supports various application layer protocols for communicating with the external world. The CCGA can act as a server, responding to requests sent by any of several protocols supported.

Application Layer Protocols

Protocol	TCP Port	UDP Port
Modbus TCP	502	
HTTPS	443	
SSH	22	
EGD		18246
SDI	5311 5313 5314 5315	
Web socket communication	7779	
NTP		123
DHCP		67 on server 68 on client

3 Security Capabilities

3.1 Firewall

The CCGA has a built-in firewall, configured to support only traffic as listed in the following table (blocking other traffic types).

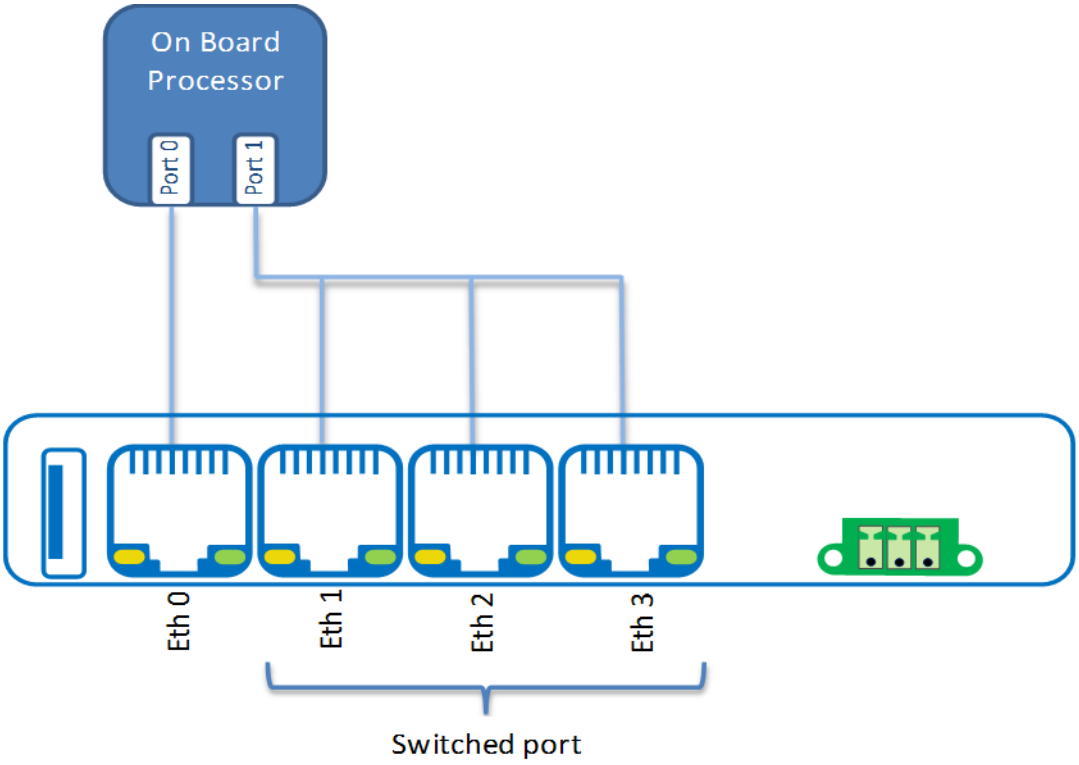
Physical Port Name	Protocol	TCP Port	UDP Port
eth0	Modbus TCP	502	
	SSH	22	
	EGD		18246
	SDI	5311 5313 5315	
	NTP		123
eth1	Modbus TCP	502	
	HTTPS	443	
	SSH	22	
	SDI	5311 5313 5314 5315 and Dynamic ports created only by CCGA	
	Web socket communication	7779	
Wi-Fi	HTTPS	443	
	Web socket communication	7779	
	DHCP		67 on server 68 on client

3.2 Wi-Fi

The Wi-Fi hotspot on the Communication Gateway (IS420CCGAH2A) is secured with WPA/WPA2 protocol. The user needs to log in with a password on the Wi-Fi. The user can access only the Lufkin web pages on the Wi-Fi. The rest of the communication on the Wi-Fi is blocked.

3.3 Routing Information

The CCGA onboard processor has two Ethernet ports (Port 0 and Port 1) as shown in the following figure. Port 0 is reserved and used for communicating with the UCPA controller (Lufkin's well controller). Any external device can communicate to the CCGA using Eth 1, Eth 2, or Eth 3 with the Port 1, IP address. Eth 1, Eth 2 and Eth 3 act like a switch port. The CCGA does not apply any firewall rules for traffic moving between Eth 1, Eth 2 and Eth 3. It applies only to traffic on Port 1. It is the user's responsibility to either use a secured product or to manage the traffic in a secure way by applying appropriate security measures.



3.4 Password management

3.4.1 SSH login

The CCGA manages three SSH login passwords.

- Password for SSH login as root (root user, full privileges)
- Password for SSH login as geapp (application engineer, controlled access to few folders)
- Password for SSH login as user (end user, controlled read access to few folders)

The user must change the default username and password in a production setting.

➢ **To change the username and password**

1. Login to communication gateway using SSH with a login ID for which user intended to change password
2. On command prompt, issue command:
   `passwd`
3. Enter the old password when prompted.
4. Enter the new password when prompted.
5. Reenter the new password when prompted.
6. If communication gateway accepts the password, it logs the message on the SSH.

3.4.2 Wi-Fi login

The user must change the default SSID and password of the Wi-Fi login.

➢ **To modify the Wi-Fi login**

1. Login to the CCGA using SSH as root/geapp.
2. Edit the file */etc/hostapd.conf*
3. Change the value assigned to tag ssid by changing the SSID ssid=<new SSID>
4. Change the value assigned to tag wpa_passphrase by changing the Wi-Fi login password Wpa_passphrase=<new password>



Attention

GEIP does not recommend changing any other setting in the */etc/hostapd.conf* file. This may result in a compromise of security.

3.4.3 Selecting a Strong Password

GEIP strongly recommends using a strong password for both the SSH and the Wi-Fi. The following are guidelines for setting a strong password.

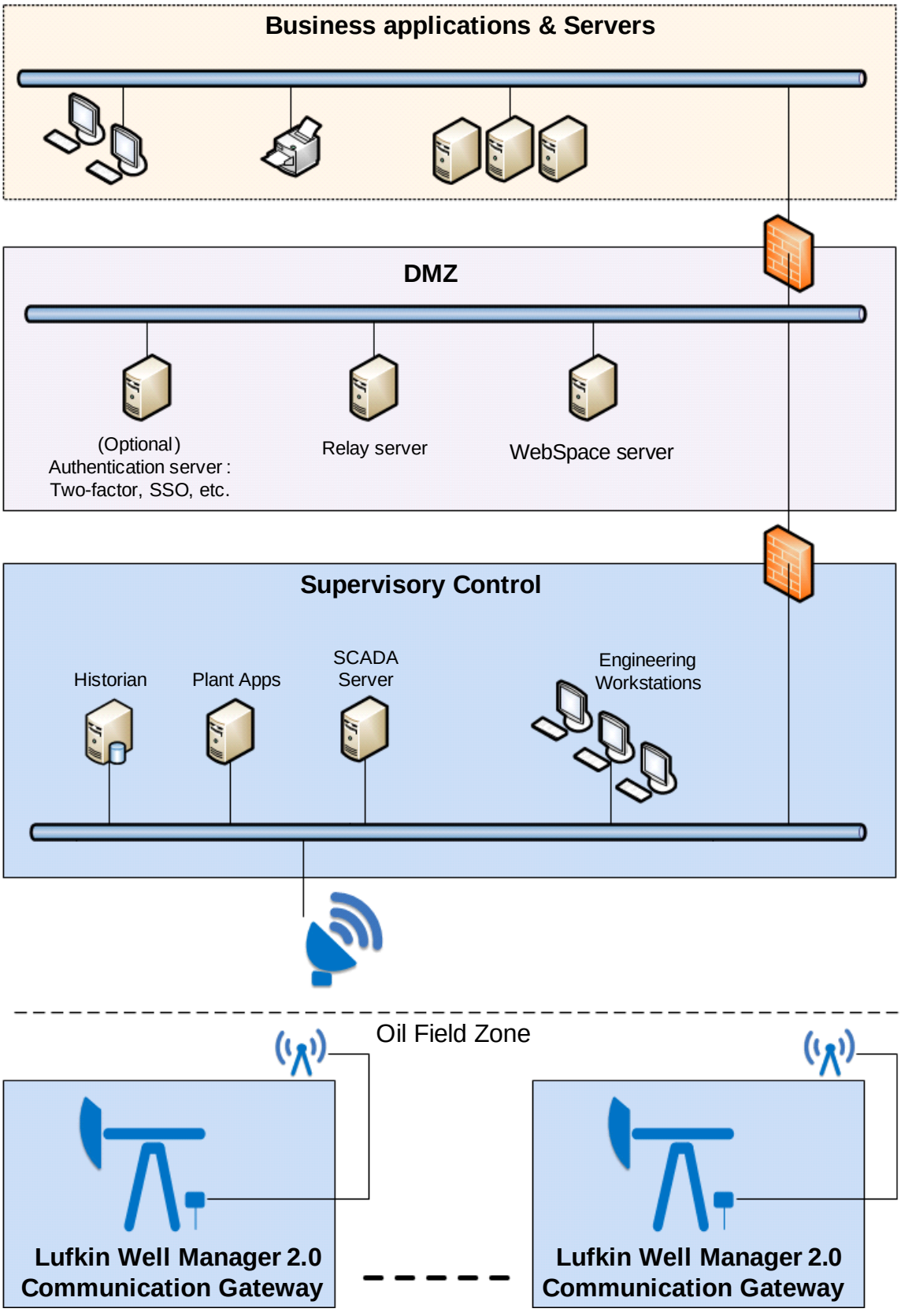
- Password length must be greater than 12.
- Password must not contain name of user, product or company.
- Password must not contain common words.
- Password must not contain personal information.
- Password should be significantly different from passwords used previously.
- Password must contain at least one capital letter, small letter, digit, and special character (like @, !, [,], {, }).

4 Network Architecture & Secure Deployment

The following sections provide security recommendations for deploying the Communication Gateway Module (CCGA) in the context of a larger network.

4.1 Reference Architecture

The following figure displays an *Example Deployment of CCGA*. The Supervisory Control Zone networks are segregated from other untrusted networks such as the enterprise network (also referred to as the business network, corporate network, or intranet) and the internet using a Demilitarized Zone (DMZ). The Process Control networks must have limited exposure to traffic from higher-level networks.



Example Deployment of CCGA

4.2 Remote Access and Demilitarized Zones (DMZ)

A DMZ architecture uses two firewalls to isolate servers that are accessible from untrusted networks. The DMZ should be deployed such that only specific (restricted) communication is allowed between the business network and the DMZ, and between the control network and the DMZ. The business network and the control networks generally do not communicate directly with each other.

If direct communication to a control network is required from the business network or from the internet, carefully control, limit and monitor all access. For example, require two factor authentication for a user to obtain access to the control network using Virtual Private Networking (VPN) and even then, restrict the allowed protocols/ports to just the minimum set required. Furthermore, every access attempt (successful or not) and all blocked traffic should be recorded in a security log that is regularly audited.

4.3 Additional Guidance

4.3.1 Protocol-specific Guidance

Protocol standards organizations may publish guidance on how to securely deploy and use their protocols. Such documentation, when available, should be considered in addition to this document.

4.3.2 Government Agencies & Standards Organizations

Government agencies and international standards organizations may provide guidance on creating and maintaining a robust security program, including how to securely deploy and use control systems. For example, the U.S. Department of Homeland Security has published guidance on *Secure Architecture Design* and on *Recommended Practices for Cyber-security with Control Systems*. Such documentation, when appropriate, should be considered in addition to this document. Similarly, the International Society of Automation publishes the ISA-99 specifications to provide guidance on establishing & operating a cyber-security program, including recommended technologies for industrial automation and control systems.

Notes



GE Automation & Controls
1-800-433-2682
1-434-978-5100
www.geautomation.com